IMPERATOR
Memoria del TFG local

Gestión y trazabilidad de decisiones operativas

Daniel Millan Perez
Desarrollo de Aplicaciones Multiplataforma

Proyecto académico local con datos sintéticos. Fuente revisada 30a03da. Memoria preparada para revisión; TFG-A sigue en progreso.

Índice

Resumen y Abstract 3
1 Contexto y objetivo del proyecto 4
2 Alcance y usuarios 5
3 Requisitos funcionales 6
4 Requisitos no funcionales 7
5 Metodología y reducción de alcance 8
6 Planificación y presupuesto 9
7 Licencia y marco de datos 10
8 Arquitectura del sistema 11
9 Estructura y tecnologías 12
10 Modelo conceptual de datos 13
11 Modelo relacional y restricciones 14
12 Migraciones y privilegios 15
13 Implementación del backend 16
14 Interfaz y experiencia de revisión 17
15 Estados y secuencia de gobernanza 18
16 Ledger y trazabilidad 19
17 Cálculo y validación del valor 20
18 Autenticación y autorización 21
19 Seguridad y decisión temporal R20 22
20 Pruebas y límites de evidencia 23
21 Persistencia y recuperación local 24
22 Instalación y preflight 25
23 Manual del flujo por roles 26
24 Bitácora y trazabilidad de trabajo 27
25 Resultados y límites 28
26 Bibliografía y fuentes verificables 29

Resumen y Abstract

IMPERATOR conecta hechos operativos con recomendaciones deterministas, revisión humana y un resultado validado. El MVP utiliza Java/Spring Boot, una interfaz Next.js y PostgreSQL para un caso sintético con treinta evidencias y cuatro roles. Su contribución es conservar la relación entre justificación, responsabilidad y valor observado. Se han verificado autenticación, autorización por actor, Flyway, privilegios, persistencia y recuperación local. La evaluación histórica contiene 174 tests unitarios, 35 integración y 41 frontend; la nueva ejecución técnica local y los escaneos del 14/10 se registran por separado. El conjunto de 25 CVE aceptado temporalmente conserva los mismos digests y vence 16/10/2026 00:00 Europe/Madrid. A-S3 de evidencia/versionado queda cerrado; memoria, defensa oral y revisión académica completan A-S4. AWS, producción, datos reales y proveedores externos permanecen fuera del alcance autorizado.

Palabras clave trazabilidad gobernanza PostgreSQL RBAC evidencia

Abstract

IMPERATOR links operational evidence to deterministic recommendations, human review and a validated outcome. The local academic MVP combines a Java/Spring Boot modular backend, a Next.js workspace and PostgreSQL persistence. One synthetic case uses thirty evidence records and four roles. Evaluation covers authentication, actor authority, Flyway, append-only application privileges, persistence and dependency recovery. Historical unit, integration and frontend results are distinguished from the new technical rehearsal and independent scans. Residual risk is explicitly and temporarily accepted for four immutable local image indices; it is neither repaired nor declared inexploitable. The evidence/version gate is complete, while the final oral rehearsal and academic review remain pending. No live AWS deployment, real data or provider validation is claimed.

1 Contexto y objetivo del proyecto

IMPERATOR trata la trazabilidad de una decisión operativa. Los equipos suelen disponer de registros técnicos, pero la evidencia que motivó una propuesta, la regla usada para evaluarla y la persona que la autorizó pueden quedar separadas. También resulta fácil confundir una expectativa económica con un resultado confirmado.

El objetivo es conectar esos elementos en una aplicación local reproducible: hechos normalizados, decisión, recomendación determinista, revisión humana, historial y valor validado. El caso elegido permite comprobar el contrato de principio a fin con datos sintéticos. La utilidad se evalúa por la coherencia del recorrido y la posibilidad de reconstruirlo, sin atribuir ahorros reales a una organización.

La versión revisada procede de main 30a03da. El backend, la interfaz y la persistencia ya existen; esta fase final organiza evidencias y defensa. R-20 tiene una aceptación temporal para cuatro imágenes locales concretas. AWS y la validación real de proveedores continúan bloqueados. El cierre académico requiere todavía revisión y una defensa oral medida.

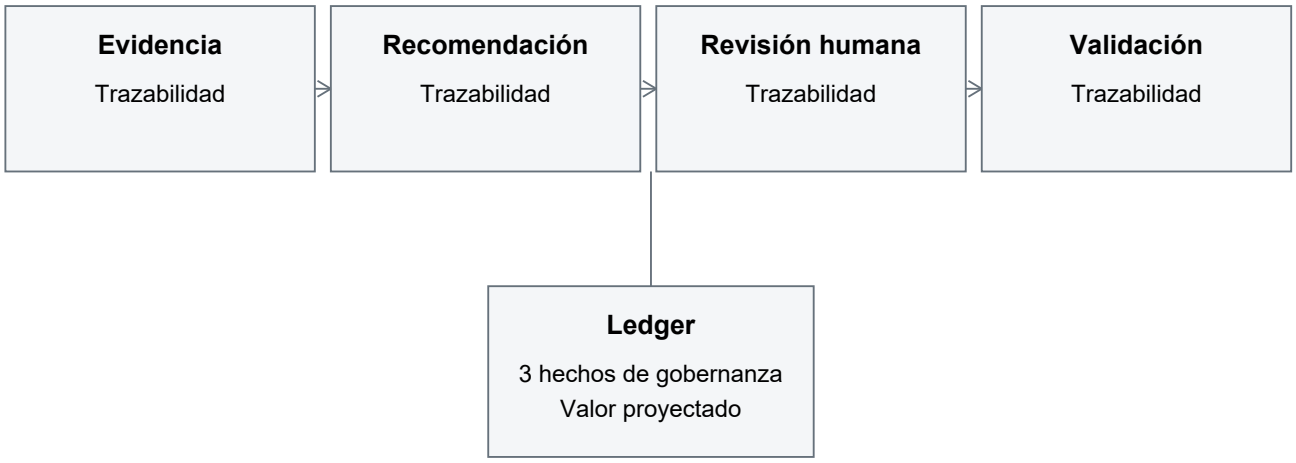


Figura Modelo de lectura del sistema implementado. Los scripts y clases versionados son la referencia física.

2 Alcance y usuarios

El MVP contiene un único caso, DRC-AOA-001, sobre recuperación de coste de un asistente de incorporación. Utiliza treinta hechos y cuatro actores sintéticos. La responsabilidad no depende solo del rol: el servidor comprueba la persona asignada y el estado de la decisión antes de aceptar un comando.

ADMIN importa y compone el caso y es el aprobador asignado en esta demostración. PLATFORM_ENGINEER registra la implementación; FINANCE valida el resultado; AUDITOR consulta. La distribución sirve para evaluar responsabilidades diferentes. El rol ADMIN como aprobador constituye una simplificación del caso académico, documentada en el alcance.

Quedan fuera datos reales, exposición pública, multitenencia, nuevos casos, nuevos servicios y automatización autónoma. No se añade un sistema comercial de acceso ni se sustituye el IdP externo mediante el fixture JWT local. El adaptador de explicación puede fallar sin alterar el resultado de negocio.

Rol	Responsabilidad
ADMIN	Importación, composición y aprobación asignada
PLATFORM_ENGINEER	Hecho de implementación
FINANCE	Validación financiera con evidencia posterior
AUDITOR	Consulta y reconstrucción sin escritura

3 Requisitos funcionales

La matriz de requisitos enlaza cada comportamiento con pruebas o evidencias concretas. El criterio consiste en demostrar el requisito dentro del caso canónico, no en convertir la aplicación en un motor genérico de procesos. La explicación opcional se evalúa mediante pruebas offline; su existencia no prueba una invocación real a Bedrock.

La aprobación por interfaz y los comandos de implementación/validación por API están identificados en la captura técnica. No se presenta como probado el selector UI de evidencias posteriores todavía no vinculadas. Esta distinción preserva el alcance de lo observado.

ID	Resultado requerido
RF01	Importar hechos normalizados y conservar referencias
RF02	Componer una decisión trazable para el caso canónico
RF03	Calcular una recomendación e importe deterministas
RF04	Exigir revisión y autoridad humana
RF05	Conservar hechos ordenados del Ledger
RF06	Proyectar valor desde resultados validados
RF07	Consultar el caso en el workspace por rol
RF08	Explicar opcionalmente sin autoridad de negocio

4 Requisitos no funcionales

La separación de dominio y adaptadores permite evaluar la política sin iniciar infraestructura. La autenticación, el control de rutas y la autoridad de negocio son controles diferentes; se verifican en servidor. Las migraciones y restricciones PostgreSQL refuerzan las invariantes, y la cuenta de aplicación tiene privilegios distintos de la cuenta de migración.

Reproducibilidad significa identificar entradas, fuente, artefactos y resultados. Una etiqueta mutable o un badge sin SHA no demuestra qué imagen se ejecutó. Los servicios se exponen solo en loopback en el ensayo local, con usuarios de contenedor restringidos y límites de recursos. Las medidas reducen exposición pero no garantizan ausencia de vulnerabilidades.

Los tests de interfaz con interceptores se separan del ensayo contra la API real. La disponibilidad cloud, la identidad externa y la recuperación de desastre no se infieren de un contenedor local saludable.

ID	Criterio
NFR01	Dependencias hexagonales y dominio independiente
NFR02	JWT, RBAC, actor y transición fail closed
NFR03	Redacción de datos y ausencia de secretos
NFR04	Persistencia, transacciones y migración
NFR05	Liveness, readiness, métricas y logs acotados
NFR06	Imágenes endurecidas e identificables
NFR07	Checks de suministro y evidencia versionada

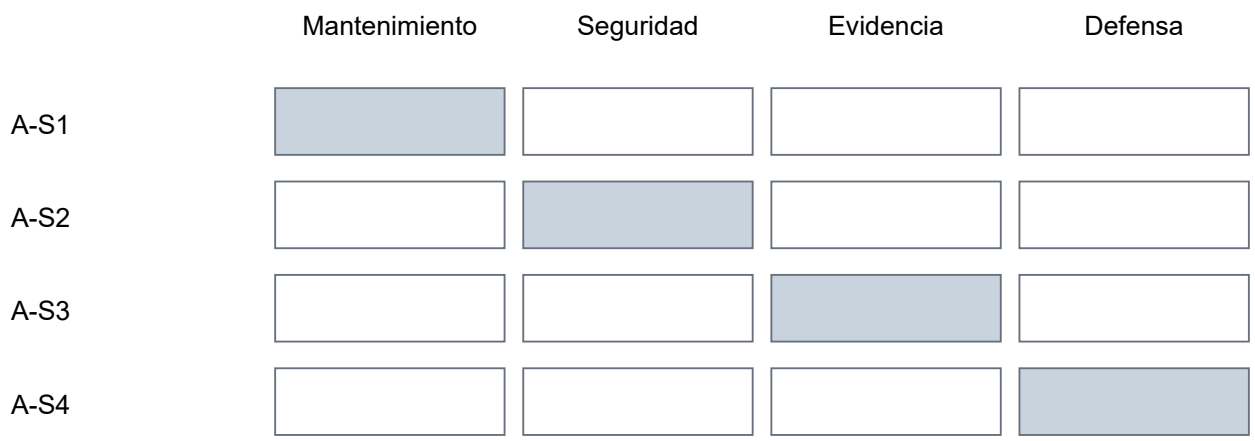
5 Metodología y reducción de alcance

El trabajo se organiza en entregables pequeños con requisitos, verificación y evidencia de salida. A-S1 abordó únicamente los parches autorizados. A-S2 separó el resultado técnico de la decisión de riesgo. A-S3 fija una versión y enlaza fuente, imágenes e informes; A-S4 convierte esa evidencia en memoria y defensa.

Cuando el scanner identifica un componente vulnerable, primero se revisan paquete, versión, advisory, fix y condiciones de exposición. La presencia del paquete no establece por sí sola exploitabilidad del servicio. Tampoco un riesgo aceptado se considera corregido. Las actualizaciones quedan limitadas al objeto autorizado, con regresión cuando cambia un artefacto ejecutable.

La reducción de alcance conserva un monolito, un workspace, un caso y cuatro roles. Se aplazan cloud, agentes, RAG, colas, cache, otros microservicios y capacidades comerciales. Así, la fase de cierre puede centrarse en consistencia, reproducción y comunicación de lo implementado.

Los gates distinguen ejecución, preparación documental y aprobación humana. Editar un estado no satisface el criterio que lo respalda. Las evidencias originales se conservan y las decisiones nuevas se añaden como registros separados.



Dependencias relativas entre fases sin escala de horas ni fecha de entrega

Figura Dependencias relativas de las fases A-S1 a A-S4.

6 Planificación y presupuesto

La temporalización final se expresa por hitos y dependencias, sin fijar una fecha de entrega. A-S3 necesita una decisión de riesgo vigente y una versión revisada. A-S4 necesita memoria, preflight, ensayo, grabación y revisión académica. Un cambio en los artefactos o una caducidad obliga a revisar la autorización antes de ejecutar.

Para mostrar un método de presupuesto se utiliza un escenario académico explícitamente estimado, sin presentarlo como horas realmente invertidas o tarifa de mercado:168 horas a 15 EUR/h, distribuidas en desarrollo 120, validación 24 y documentación 24. El total del escenario es 2520 EUR. La bitácora real conserva hitos pero no contiene un registro completo de horas; por ello no calcula el coste real de trabajo.

No se han contratado recursos AWS en esta fase. El equipo y las herramientas existentes no se valoran como si se hubieran comprado para el proyecto. El total estimado de trabajo no equivale al importe económico simulado del caso.

Escenario académico	Horas asumidas	Coste a15 EUR/h
Desarrollo	120h	1800 EUR
Validación	24h	360 EUR
Memoria y defensa	24h	360 EUR
Total estimado	168h	2520 EUR

7 Licencia y marco de datos

El archivo LICENSE del repositorio reserva los derechos del autor y permite revisión de portfolio, evaluación educativa y técnica conforme a sus términos. La disponibilidad pública no concede una licencia de código abierto. Las bibliotecas de terceros conservan sus licencias y deben citarse de forma independiente.

Como marco de referencia para una eventual gestión de datos personales se identifican el Reglamento UE 2016/679 y la Ley Orgánica 3/2018. La ley española desarrolla la protección de datos personales y los derechos digitales. La evaluación de IMPERATOR utiliza identidades y hechos sintéticos; el alcance autorizado excluye introducir datos reales.

Una futura aplicación a personas reales exigiría revisar finalidad, base jurídica, responsables, información, conservación y ejercicio de derechos. Esta memoria no acredita una evaluación jurídica completa de ese escenario. Los tokens, claves privadas, credenciales y dumps se mantienen fuera del repositorio y de la grabación.

Fuentes oficiales consultadas: BOE, Ley Orgánica 3/2018; EUR-Lex, referencia del Reglamento UE 2016/679. La revisión legal de un despliegue real permanece fuera del MVP local.

8 Arquitectura del sistema

La arquitectura es un monolito modular Java 21/Spring Boot con límites hexagonales. Domain contiene valores e invariantes; Application coordina casos de uso y transacciones; los puertos expresan contratos; los adaptadores conectan REST, JDBC y proveedores. El código de negocio no depende de Spring, HTTP, JDBC o los SDK de proveedores.

Next.js presenta el workspace y utiliza un proxy del mismo origen para la API. PostgreSQL persiste hechos y relaciones; Flyway versiona el esquema. Business Value es una proyección de hechos de gobernanza persistidos, no otro motor financiero.

Los adaptadores GitHub/AWS son de lectura acotada. El proveedor opcional de explicación actúa después de persistir el resultado determinista y no recibe autoridad para aprobar ni ejecutar. La arquitectura objetivo ECS/Fargate/RDS existe como preparación, sin ejecución real en esta fase.

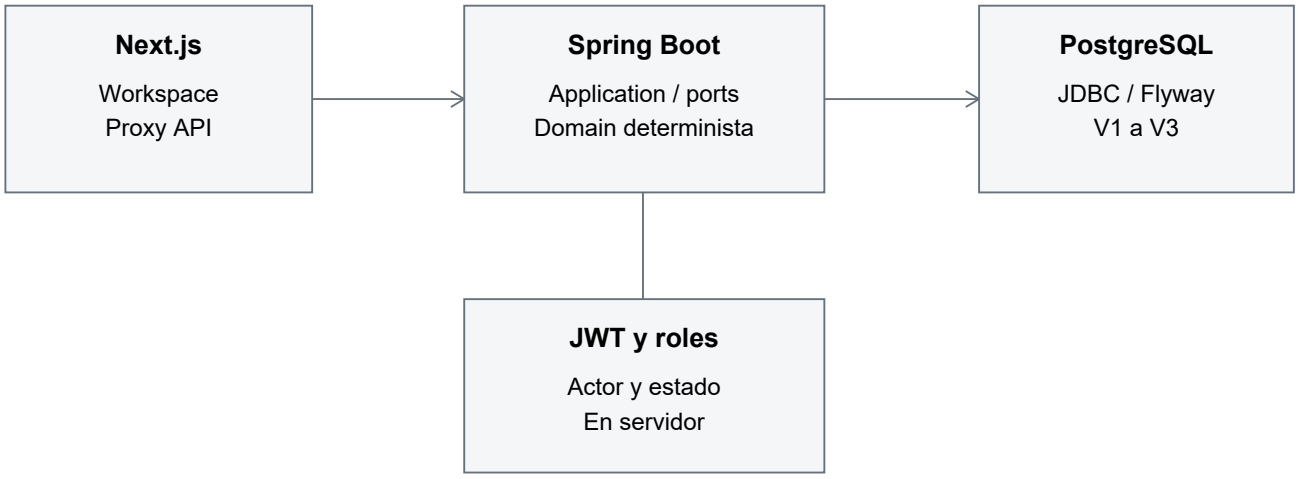


Figura Modelo de lectura del sistema implementado. Los scripts y clases versionados son la referencia física.

9 Estructura y tecnologías

El pom raíz compila producción desde backend-java y pruebas desde src/test/java. No se crea otro backend ni se reorganizan paquetes para esta entrega. frontend contiene el workspace; database/migrations contiene las migraciones; infra/docker define el runtime; docs conserva contratos, decisiones y evidencias.

Java 21, Spring Boot4.1.1, Next 16.3.8 y PostgreSQL 18.6 corresponden a las fuentes verificadas. Los números son contexto de la versión, no una instrucción para actualizarlos. La configuración de npm mantiene Node 24 y npm 11. Los lockfiles y digests ayudan a identificar las entradas usadas.

JDBC permite controlar transacciones y SQL explícitos. La infraestructura está detrás de puertos, para que las pruebas puedan evaluar políticas e invariantes por separado. Docker concentra una reproducción local; GitHub Actions y CodeQL aportan verificación del SHA integrado.

backend-python, services y otros directorios de preparación no constituyen servicios ejecutados del MVP. La guía de estructura del proyecto distingue código funcional, contratos y material auxiliar.

Ruta	Responsabilidad
backend-java	Dominio, casos de uso, puertos y adaptadores
src/test	Tests y fixtures sintéticas
frontend	Workspace, contratos UI y tests
database/migrations	SQL V1 a V3
infra/docker	Imágenes y Compose local
docs/tfg	Requisitos, riesgos, memoria y evidencias

10 Modelo conceptual de datos

Evidence representa un hecho normalizado con origen, referencia, significado, correlación, sensibilidad y revisión. Decision identifica el caso, propietario y aprobador. Recommendation conserva el resultado de política, importe estimado, tipo, riesgo y confianza. LedgerEntry conserva hechos de gobernanza con actor, instante, motivo y referencias.

Las relaciones de evidencia se materializan mediante tablas puente. Una decisión tiene una recomendación propia y puede tener varias entradas de Ledger. Cada entrada enlaza la anterior para reconstruir la secuencia. Las referencias ayudan a verificar la justificación y el resultado sin copiar payloads sensibles.

El esquema de explicaciones mantiene intentos, estado, proveedor y referencias por separado. Su ausencia o fallo no destruye la recomendación. El diagrama resume la relación conceptual; la autoridad del modelo físico corresponde a los scripts de migración versionados.

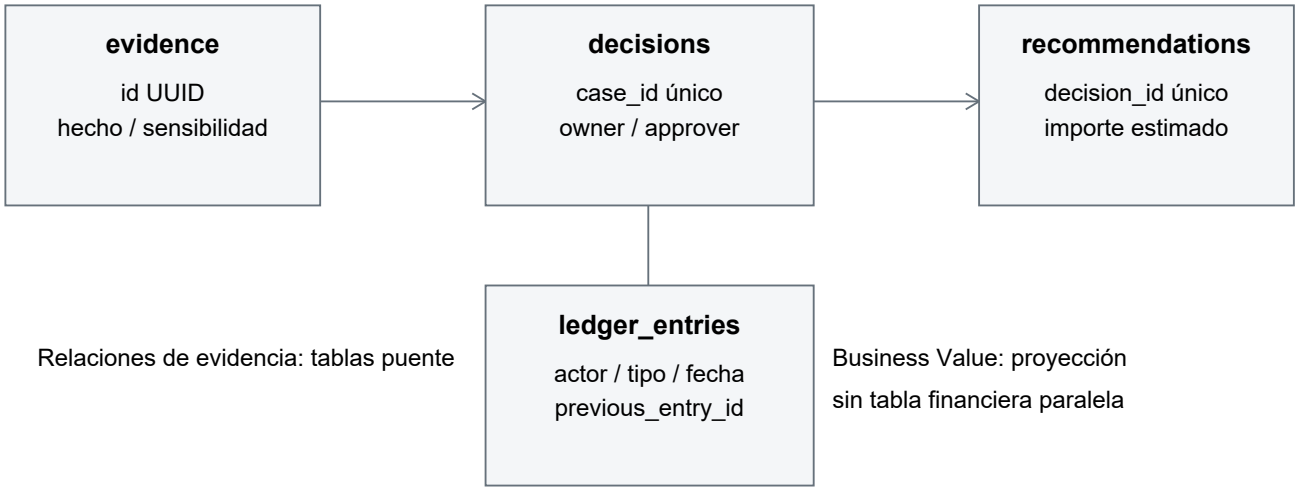


Figura Modelo de lectura del sistema implementado. Los scripts y clases versionados son la referencia física.

11 Modelo relacional y restricciones

V1 crea evidence, decisions, decision_evidence, recommendations, recommendation_evidence, ledger_entries y ledger_evidence_snapshots. Las clavesUUID identifican entidades; las claves compuestas de las tablas puente impiden duplicar relaciones. Las FK restringen eliminaciones y actualizaciones que romperían referencias.

El enlace de recommendations a decisions es único y la propiedad de la recomendación se comprueba mediante una referencia compuesta. Los estados de decisión están acotados por CHECK y las tuplas de revisión requieren actor, fecha y motivo coherentes. La precisión monetaria se valida en SQL y en los valores de dominio.

La columna metadata de Evidence es TEXT con validación mediante conversión a JSONB y valores planos de texto. Por ello no se describe como una columna JSONB almacenada. Esta precisión evita que el modelo dibujado sustituya lo implementado.

Business Value se calcula leyendo hechos de implementación y validación. El esquema no contiene una tabla financiera paralela para inventar un resultado independiente.

Grupo físico	Contenido
evidence	Hechos normalizados y sensibilidad
decisions	Caso, actores y revisión
recommendations	Resultado determinista y valor estimado
ledger_entries	Hechos ordenados y enlace anterior
Tablas puente	Evidencias asociadas y snapshots
V3 explicaciones	Intentos y referencias independientes

12 Migraciones y privilegios

Flyway aplica V1 para el esquema inicial, V2 para unicidad del caso y V3 para intentos de explicación. La repetición de migrate sin nuevas versiones debe ser no-op y validate comprueba coherencia. La cuenta de migración y la cuenta de aplicación tienen responsabilidades separadas.

V3 incorpora recommendation_explanations, recommendation_explanation_evidence y recommendation_explanation_assumptions. Se comprueban estado, longitud de contenido, métricas no negativas y referencias válidas. La revisión de limpieza de tests y permisos debe incluir estas tablas para evitar residuos de ejecución.

En el ensayo local se verifican SELECT e INSERT permitidos y UPDATE/DELETE denegados para la cuenta de aplicación en el Ledger y tablas de explicación. Esta propiedad no impide que el propietario administrativo cambie físicamente la base; expresa la garantía bajo la identidad normal del servicio.

La persistencia se verifica reemplazando contenedores y conservando el volumen sintético del ensayo. El objetivo es demostrar que los hechos sobreviven al ciclo de vida de procesos, no simular una restauración de desastre físico o una operación RDS.

Versión	Propósito
V1	Esquema inicial y restricciones
V2	Unicidad de case_id
V3	Intentos de explicación y referencias
Verificación	Migrate, validate, no-op y privilegios

13 Implementación del backend

ReviewDecisionUseCase valida el comando y ejecuta la operación en una transacción. Carga la decisión con bloqueo, comprueba recomendación, cronología y autoridad, y reconstruye la cadena del Ledger antes de aceptar el evento. La separación permite relacionar cada rechazo con una invariante concreta.

El fragmento mostrado procede del código propio versionado. La autoridad de una transición no se delega a un botón de la UI. Las comprobaciones de idempotencia y orden evitan convertir reintentos equivalentes en hechos nuevos inconsistentes.

Los repositorios JDBC realizan SQL parametrizado y los nombres de ordenación se traducen mediante alternativas acotadas. El contexto de seguridad llega a los casos de uso sin importar clases de framework en el dominio. Los adaptadores traducen errores técnicos sin fabricar resultados de negocio.

backend-java/application/reviewdecision/ReviewDecisionUseCase.java fragmento propio de la fuente revisada

```
return transactionRunner.execute(() -> reviewDecisionInTransaction(command, inputs));
}

private ReviewDecisionResult reviewDecisionInTransaction(
ReviewDecisionCommand command,
ReviewInputs inputs
) {
Decision decision = decisionRepository.findByIdForUpdate(command.decisionId())
.orElseThrow(() -> new DecisionNotFoundException(command.decisionId()));
Recommendation recommendation = loadRecommendation(decision);
ensureRecommendationMatchesDecision(decision, recommendation);
ensureReviewTimestamp(command, recommendation);
authorize(command, inputs.actorRole(), decision, recommendation);

List<LedgerEntry> history = ledgerRepository.findByDecisionId(decision.id());
LedgerChain chain = LedgerChain.from(decision.id(), history);
Optional<LedgerEntry> existing = ledgerRepository.findById(command.ledgerEntryId());
if (existing.isPresent()) {
return resolveReplay(command, inputs, decision, recommendation, chain, existing.get());
}

chain.requireExpectedHead(inputs.expectedPreviousEntryId());
```

14 Interfaz y experiencia de revisión

El workspace muestra contexto, coste actual, coste proyectado, recomendación, justificación, roles y valor realizado. Los contratos de lectura se validan con esquemas TypeScript. Una explicación no disponible permanece visible como estado de proveedor; el resultado determinista sigue siendo utilizable.

La captura procede del nuevo ensayo contra los contenedores reales. El token de sesión es efímero y está enmascarado. Las fechas del caso pertenecen a la fixture sintética; no son la fecha de captura. La navegación no afirma un sistema comercial de identidad o una sesión de producción.

La aprobación se realizó por UI. Para implementación y validación se usaron comandos API autenticados y luego lecturas UI. El selector de evidencias posteriores no se presenta como demostrado para registros inicialmente no vinculados. Los tests con mocks se citan aparte del ensayo real.

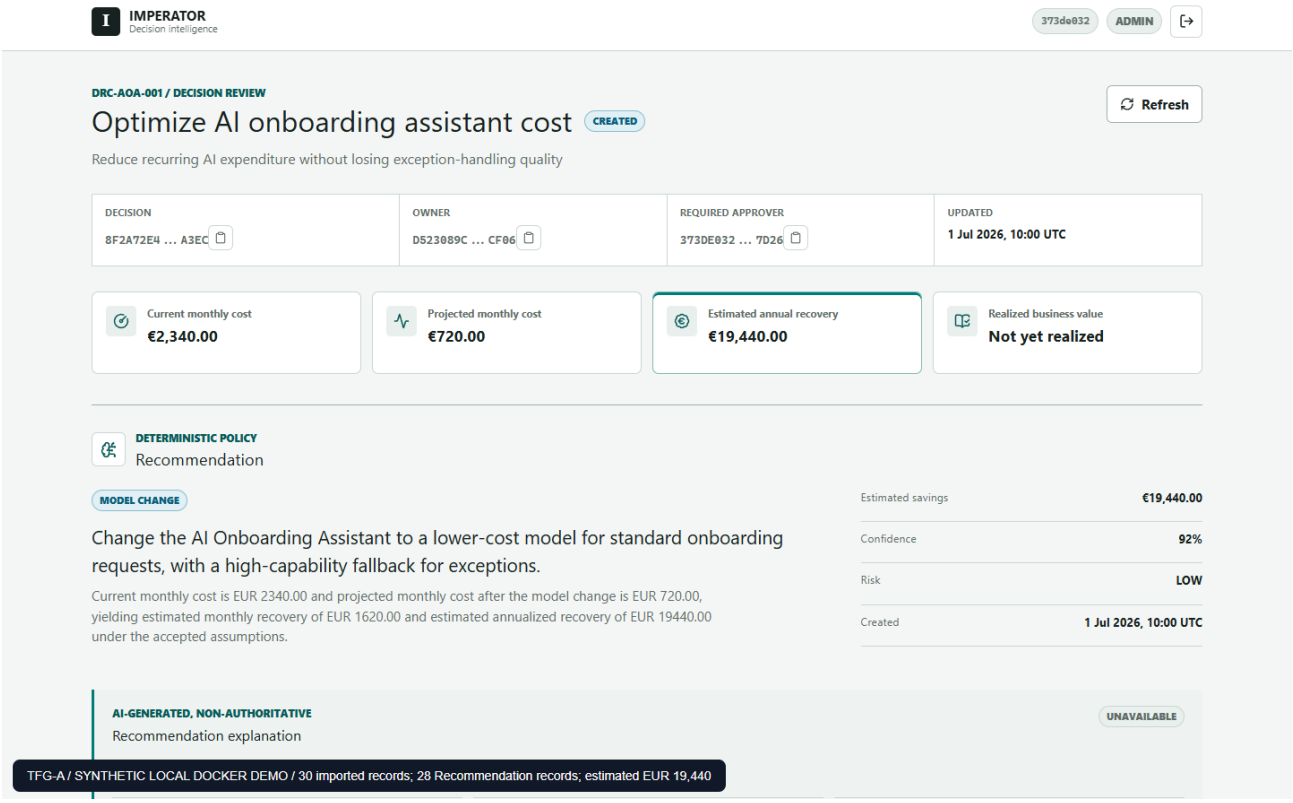


Figura Captura sintética de la ejecución técnica local del 14/10. Fechas internas de la fixture. Tokens enmascarados.

15 Estados y secuencia de gobernanza

Decision empieza en CREATED, puede entrar en UNDER_REVIEW cuando dispone de recomendación y permite resultados APPROVED, REJECTED o DEFERRED conforme a sus invariantes. La aprobación y el rechazo cierran la revisión; el aplazamiento conserva la posibilidad de volver a trabajar sobre la decisión.

La composición y la revisión son operaciones distintas. Las comprobaciones de servicio coordinan actor asignado, rol, propiedad y cronología. La implementación y validación financiera se expresan como hechos de Ledger posteriores a la aprobación, sin inventar estados IMPLEMENTED o VALIDATED en la columna status de Decision.

El ensayo crea tres hechos: aprobación, implementación y validación de resultado. Un auditor puede reconstruirlos sin obtener autoridad de escritura. La secuencia y la relación de evidencia permiten explicar quién asumió responsabilidad y qué resultado sustentó la proyección de valor.

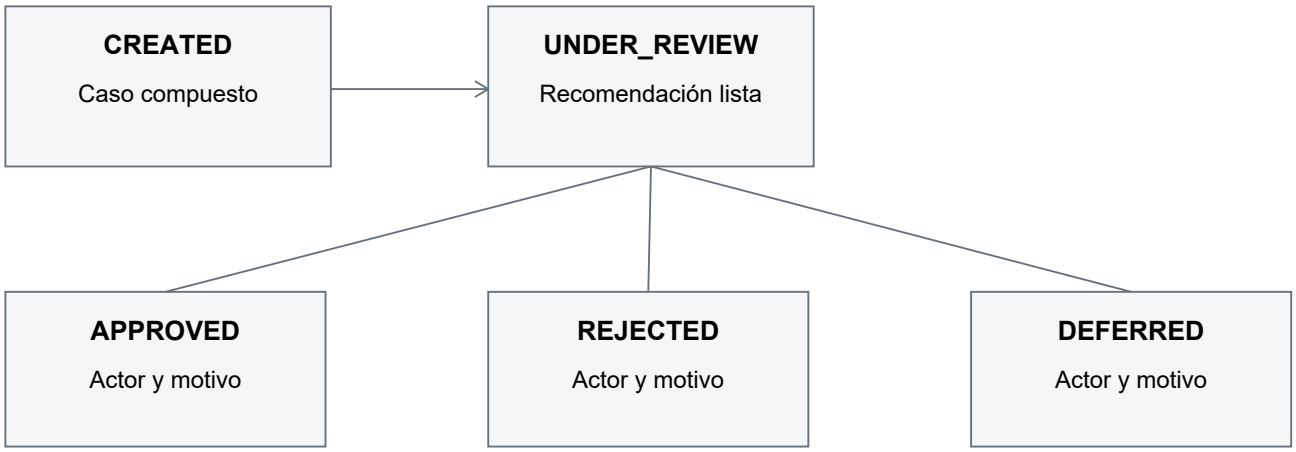


Figura Modelo de lectura del sistema implementado. Los scripts y clases versionados son la referencia física.

16 Ledger y trazabilidad

LedgerEntry es un valor de dominio con identificador, decisión, actor, rol, instante, tipo, motivo, snapshots de evidencia y enlace previo. Las colecciones se copian y los metadatos se acotan. Los tokens o payloads sensibles no deben formar parte de esa metadata.

La cadena se valida para detectar secuencias incompatibles, referencias indebidas y bifurcaciones. La restricción de escritura de la cuenta de aplicación refuerza el carácter append-only del contrato. Se distingue de una garantía criptográfica global frente al administrador de PostgreSQL.

Las proyecciones leen hechos ya persistidos. Una explicación generativa se registra por separado y no puede escribir eventos de gobernanza. La revisión puede relacionar los tres eventos con las evidencias y con el importe observado en el caso sintético.

La persistencia y el replay se sostienen mediante tests y el ensayo de recreación. El lector puede acceder a informes brutos y hashes para identificar el recorrido, en lugar de depender únicamente de una imagen o de un badge.

backend-java/domain/ledger/LedgerEntry.java fragmento propio de la fuente revisada

```
LedgerEntryId id,
DecisionId decisionId,
Optional<RecommendationId> recommendationId,
UserId actorId,
String actorRole,
Timestamp occurredAt,
LedgerEntryType entryType,
String changeSummary,
String reason,
Set<EvidenceId> evidenceSnapshotIds,
Optional<ROIAmount> estimatedSaving,
Optional<ROIAmount> realizedSaving,
Optional<ROIConfidence> confidenceSnapshot,
Optional<Severity> riskSnapshot,
Optional<LedgerEntryId> previousEntryId,
Map<String, String> metadata
) {
private static final int MAX_METADATA_ENTRIES = 10;
private static final int MAX_METADATA_KEY_LENGTH = 80;
```

17 Cálculo y validación del valor

La política del caso calcula una recuperación mensual de 1620 EUR al pasar de 2340 a 720 EUR de coste simulado. Su anualización produce 19440 EUR. El valor validado de 18960 EUR se apoya en los hechos posteriores del caso; la variación respecto al estimado es -480 EUR.

Estas cantidades permiten probar cálculo y proyección con resultados exactos. No representan ahorro real de cliente, precio vigente de un servicio cloud ni coste de despliegue. La confianza del 92% mostrada forma parte de la política del caso y no se interpreta como exactitud estadística de un modelo aprendido.

Business Value requiere un hecho de implementación y una validación posterior bajo las responsabilidades correctas. Una aprobación sin resultado no basta para afirmar valor realizado. La diferenciación entre expectativa y resultado es una de las utilidades principales del sistema.

Magnitud del caso	Valor sintético
Coste mensual actual simulado	2340 EUR
Coste mensual proyectado	720 EUR
Recuperación mensual estimada	1620 EUR
Anualización estimada	19440 EUR
Anualización validada sintética	18960 EUR
Variación	-480 EUR

18 Autenticación y autorización

El recurso REST valida JWT firmado con RS256 y JWKS, issuer, audience, tiempos, subject UUID, kid y el rol exacto. En el ensayo se usa un emisor HTTPS/JWKS local con claves efímeras. Esa herramienta verifica el contrato local y no acredita conformidad operativa de Keycloak externo.

RBAC concede rutas y métodos concretos. Después, la autoridad de negocio comprueba actor asignado y transición. El servidor responde 401 sin autenticación y 403 cuando el auditor intenta escribir; el Ledger no crece por ese intento denegado.

La exposición del ensayo queda en loopback para frontend. Backend, PostgreSQL y gestión permanecen internos. Se separan secretos del propietario y de aplicación mediante archivos privados del ensayo, sin persistir tokens en comandos, informes o grabaciones.

El control se complementa con redacción de Evidence según sensibilidad. Un token en memoria y una UI que oculta botones no son por sí solos una garantía; el contrato efectivo reside en las comprobaciones del servidor y del dominio.

19 Seguridad y decisión temporal R20

La aceptación del 14/10 se limita a los cuatro digests locales inspeccionados, al entorno local y a datos sintéticos. Conserva 25 CVE / 119 combinaciones de paquete y versión con la clasificación conservadora del 13/10. Caduca de forma exclusiva el 16/10/2026 a 00:00 Europe/Madrid, equivalente a 15/10/2026 22:00 UTC. No se renueva ni transfiere a imágenes futuras o de CI.

Aceptar riesgo no corrige un componente ni demuestra inexplotabilidad. El nuevo escaneo independiente 14/10 mantiene 0 High/Critical corregibles y 0 secretos. Dos CVE conocidas de GnuTLS siguen affected sin fix y pasan de HIGH a LOW en el scanner. Se conservan 23 CVE H/C y las dos LOW dentro del mismo conjunto aprobado; no se retiran del registro aceptado.

El diagnóstico inicial comparaba únicamente H/C y detectó un delta. La revisión posterior confirmó todas las identidades aprobadas, sin nuevos paquetes, versiones o CVE de alto riesgo. Se preservan ambos registros. Nuevos riesgos, fixes aplicables, cambios de configuración/digest o caducidad mantienen la obligación de detener y revisar.

R-23 es independiente: braces permanece en el tooling, no se identificó como paquete de producción y el advisory no publica versión corregida. npm propone un cambio mayor de eslint-config-next; no se aplica ni se presenta como fix del paquete.

20 Pruebas y límites de evidencia

La regresión funcional conservada del 09/10 registra 174 unitarios backend, 35 integración PostgreSQL y 41 frontend aprobados. Lint, tipos, formato y build también pasan. Playwright tiene 9 casos aprobados y 6 skips intencionales; los skips no se cuentan como éxito.

El ensayo Docker del 14/10 se ha ejecutado de nuevo con la API real, las cuatro imágenes aceptadas, fixture local, credenciales y volumen sintéticos nuevos. No se reconstruyen imágenes ni se llama a AWS o proveedores. La fuente del helper de captura coincide byte a byte con la de la versión revisada.

La CI del SHA 30a03da tiene 10 checks correctos. Sus imágenes reconstruidas tienen identidades propias y no se confunden con el runtime local. El resultado CI no aprueba por sí mismo el riesgo residual ni constituye revisión académica.

El conjunto de pruebas apoya las afirmaciones dentro de sus entradas y alcance. No demuestra cumplimiento global, resistencia a cualquier atacante ni disponibilidad cloud. Los informes originales, los fallos de configuración históricos y las fechas se conservan.

Control	Resultado y fecha
Unitarios / integración / frontend	174 / 35 / 41 PASS históricos 09/10
Playwright	9 PASS /6 skips intencionales
Escaneo independiente 14/10	0 corregibles H/C y 0 secretos
npm producción / tooling	0 / 5 High R-23
Runtime 14/10	API/UI real, mismos digests y datos sintéticos

21 Persistencia y recuperación local

El ensayo verifica que un volumen sintético conserva treinta evidencias y tres entradas de Ledger después de reemplazar frontend, backend y PostgreSQL. Las identidades de imagen permanecen iguales y las proyecciones económicas y la secuencia de hechos no cambian.

Flyway registra V1 a V3 exitosas. Se consultan privilegios SELECT/INSERT permitidos y UPDATE/DELETE denegados en el Ledger y las tablas de explicación para la cuenta de aplicación. La cuenta de migración mantiene responsabilidades administrativas distintas.

Para comprobar readiness se detiene únicamente PostgreSQL de ese ensayo aislado. El backend deja de estar preparado y responde 503 en readyz, mientras livez continúa 200. Al restablecer la base, readiness vuelve 200 y los hechos y el valor permanecen iguales.

La intervención afecta solo recursos creados para esta ejecución. No se reinicializa una base normal del proyecto, no se podan imágenes ni se eliminan volúmenes previos. Estas pruebas son de recuperación local por dependencia y recreación de procesos, no de restauración cloud o desastre físico.

Situación	Observación
Estado saludable	readyz 200 / livez 200
PostgreSQL detenido	readyz 503 / livez 200
Recuperación	readyz 200 / livez 200
Datos conservados	30 evidencias / 3 Ledger
Artefactos	Mismos cuatro índices aceptados

22 Instalación y preflight

La reproducción requiere Docker en modo Linux, herramientas compatibles y las cuatro imágenes exactas disponibles. El harness de la defensa utiliza overrides de imagen, --no-build y --pull never, un proyecto Compose exclusivo y un volumen sintético nuevo. No se reemplazan por una compilación nueva sin revisión.

Antes de iniciar deben comprobarse fecha y caducidad de R-20, identidad de índice/plataforma/origen/capas, gates de escaneo y ausencia de secretos. El frontend se publica exclusivamente en 127.0.0.1; el emisor local no tiene puerto público. Los proveedores externos permanecen desactivados.

Los secretos se generan en un directorio privado bajo build y se inyectan mediante archivos. Los tokens llegan al helper por stdin y no se imprimen ni se guardan en el informe. Los comandos genéricos de Compose delmanual técnico contienen build contexts; por eso no sustituyen el preflight revisado del ensayo.

La instalación académica usa datos sintéticos y no añade un proveedor externo. Al caducar la aceptación, los archivos de evidencia siguen siendo consultables como historia, mientras una nueva ejecución exige decisión vigente.

23 Manual del flujo por roles

El operador ADMIN introduce una fixture normalizada y compone DRC-AOA-001. El workspace presenta contexto, referencias y recomendación. Se comprueba que la cifra es la prevista por la política y que el valor realizado aún no se afirma antes de los hechos posteriores.

El aprobador asignado revisa y registra el motivo. Un actor distinto o un rol sin permiso no puede sustituirlo. Después PLATFORM_ENGINEER registra la implementación con evidencia posterior, y FINANCE valida el resultado. La UI lee el estado tras los comandos autenticados de API.

AUDITOR recorre los hechos y proyecciones de lectura. Su intento de escritura es denegado y no altera la cadena. Ante un 401 se revisa autenticación; ante 403 se revisan permisos/actor; ante conflicto se revisan estado, cronología o idempotencia. No se reintenta cambiando personas o borrando datos para forzar aceptación.

Para la defensa se emplea un caso y una base de ensayo aislados. Las capturas y la narración deben identificar cuándo una acción es ejecutada, cuándo es una lectura y cuándo se muestra evidencia registrada. Una pantalla grabada no se representa como una nueva interacción.

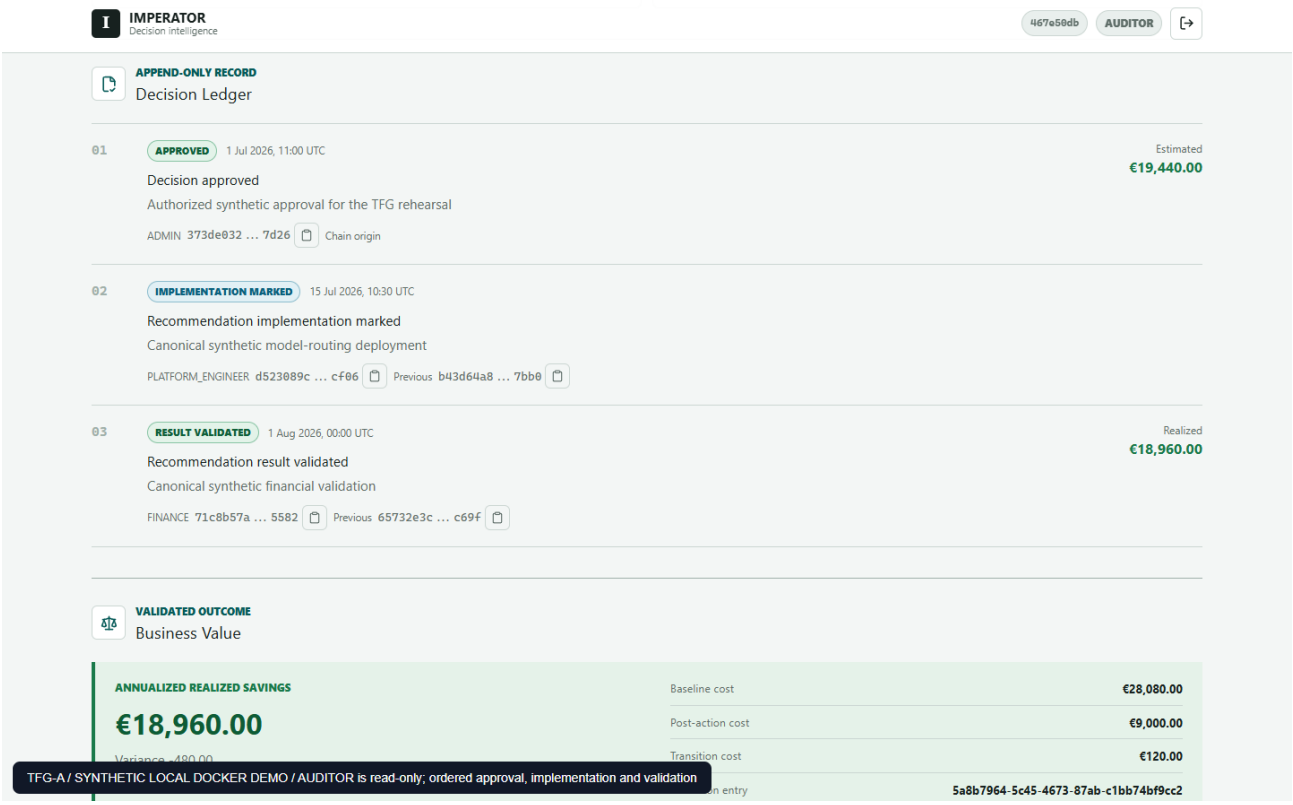


Figura Captura sintética de la ejecución técnica local del 14/10. Fechas internas de la fixture. Tokens enmascarados.

24 Bitácora y trazabilidad de trabajo

La bitácora se reconstruye a partir de registros versionados y evidencias fechadas. No atribuye horas que no están registradas. El lector puede localizar decisiones y resultados por sus packs, hashes y commits. La fuente de verdad es el repositorio y los informes concretos, no la descripción narrativa.

Los hitos reflejan mantenimiento acotado, separación de riesgo técnico/humano y consolidación de una defensa local. Las discrepancias de finales de línea se documentan sin alterar los bytes de evidencias aprobadas. El SHA histórico b02e3e2 y sus receipts se mantienen, aunque la entrega actual usa otra fuente documental.

La planificación restante conserva dependencia de ensayo oral y revisión académica. La duración real del ensayo humano y cualquier corrección posterior se incorporarán con fecha y resultado verificables; no se sustituyen por los 720 segundos planificados del guion.

Hito documentado	Resultado / siguiente evidencia
Semana 40	Regresión local y remediación original R-17; registros01-02/10
Semana 41	R-19/R-21/R-22, revisión residual, Go 1.26.9 y ensayo 09/10
Semana 42	Integración main, presentación, aprobación R-20 y revalidación 14/10
Pendiente	Ensayo oral humano y revisión académica

25 Resultados y límites

El resultado demuestra que una colección de hechos puede originar una recomendación reproducible, mantenerse bajo responsabilidad humana y proyectar un valor sustentado en hechos posteriores. La arquitectura, las restricciones de datos y las pruebas de permisos apoyan la coherencia del recorrido.

A-S3 cierra la versión y evidencia local con una aceptación residual explícita y temporal. A-S4 avanza con memoria y material de defensa, pero la duración del ensayo oral y la revisión académica requieren participación humana. La aprobación de riesgo no sustituye esas obligaciones.

Se conservan como límites: un caso sintético, cuatro roles, comandos de implementación/validación mediante API, explicación offline, riesgo del tooling abierto y ausencia de validación AWS e IdP externo. La cifra económica es simulada. No se ofrece una garantía absoluta de seguridad o un sistema comercial listo para clientes.

La finalización de TFG-A se declarará solo después de comprobar la Definition of Done y las evidencias formales. No se abre AWS ni se añaden tecnologías o funcionalidades para completar esta fase.

26 Bibliografía y fuentes verificables

Repositorio de implementación: https://github.com/Dmillan-dev/ImperatorProyect. Fuente revisada: 30a03dab7d26c1ddf3b30c4ea052614efe39c405. Contratos, requisitos y decisiones se encuentran en docs/tfg, docs/architecture y docs/decisions.

Evidencias funcionales históricas: docs/tfg/evidence/2026-10-09-gosu-security-closure. Aprobación y revalidación 14/10: docs/tfg/evidence/2026-10-14-r20-acceptance. El acta A-S3 y el JSON de decisión enlazan digests, bases de scanner y hashes.

GitHub Advisory Database, GHSA-vfj7-8cjw-p6xm (braces): https://github.com/advisories/GHSA-vfj7-8cjw-p6xm. Debian Security Tracker, GnuTLS: https://security-tracker.debian.org/tracker/CVE-2026-88647 y https://security-tracker.debian.org/tracker/CVE-2026-88648. Consultas 14/10/2026.

BOE, Ley Orgánica 3/2018: https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673. EUR-Lex, referencia Reglamento UE 2016/679: https://eur-lex.europa.eu/eli/reg/2016/679/oj. El marco legal se presenta como referencia, no certificación de cumplimiento.

Criterios institucionales aportados: diapositivas 20260311 PI 10ª sesión, tareas 0 a 6; extracto de PLANTILLA_MemoriaProyecto. Requisitos de maquetación: Arial 11, interlineado 1,5 y 20-40 páginas sin anexos.

Componentes externos: Java/OpenJDK, Spring Boot, Next.js/React, PostgreSQL/Flyway, Playwright/Vitest, Trivy/Gitleaks/CodeQL y bibliotecas delpom/lockfile. Sus licencias y versiones se verifican en los manifiestos/SBOM; no se atribuye su código al autor.